Microsoft Certified: Security Operations Analyst Associate

Course

Defend against cyberthreats with Microsoft's security operations platform

---

Module 1

Mitigate threats using Microsoft Defender XDR

Modules in this learning path

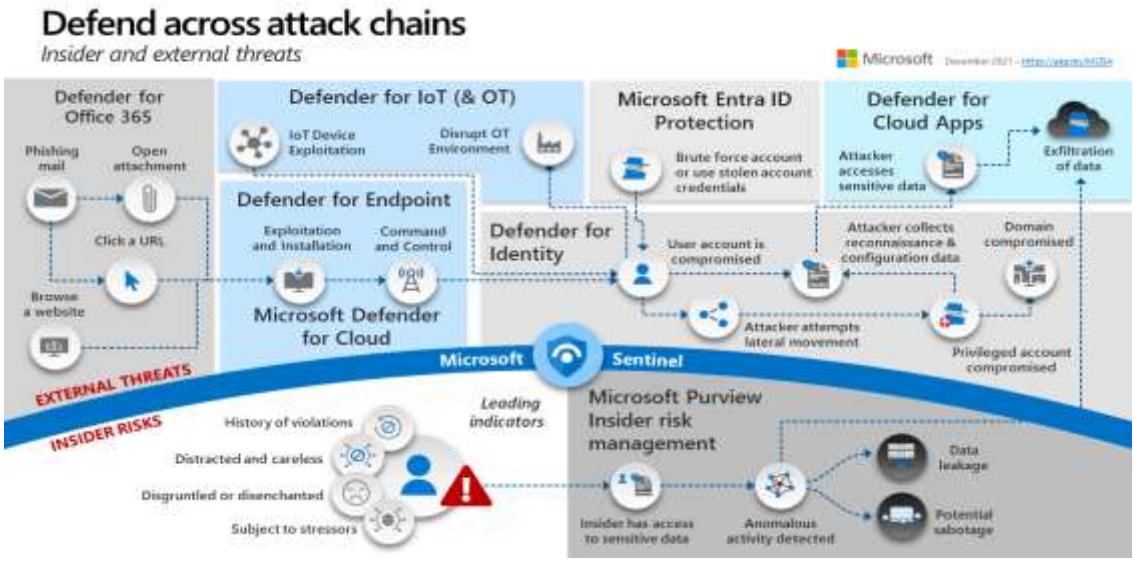
COURSE 1

Introduction to Microsoft Defender XDR threat protection

Introduction

Microsoft Defender XDR is an integrated threat protection suite with solutions that detect malicious activity across email, endpoints, applications, and identity. These solutions provide a complete attack chain compromise story that enables a complete understanding of the threat. And, enables you to remediate and protect your organization from future attacks.

In the sample attack chain graphic example, see the attacker activity visible to each Microsoft Defender XDR product.

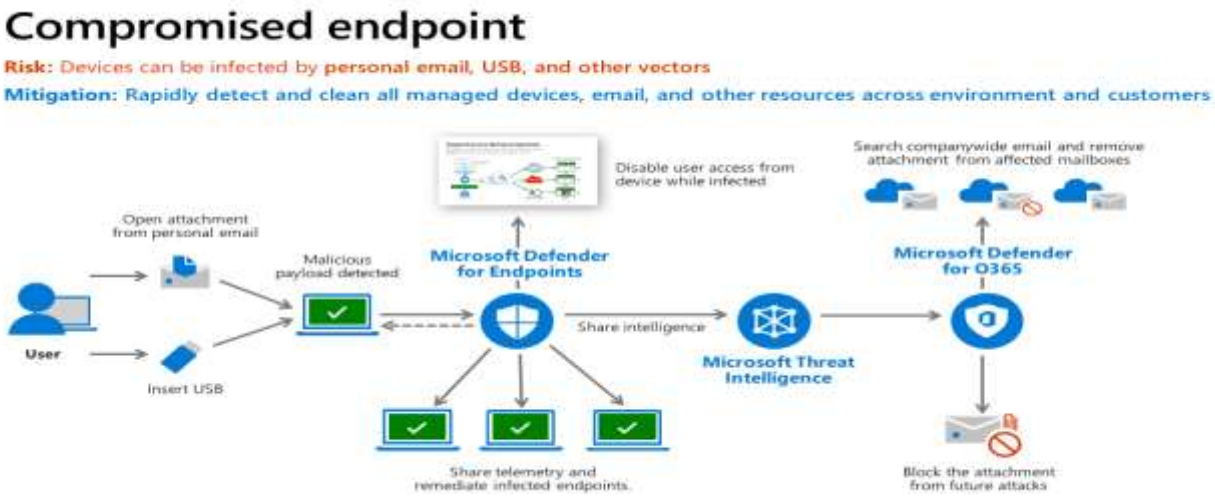


Explore Extended Detection & Response (XDR) response use cases

The following are examples of detection and mitigation use cases.

Detection of Threat

This scenario depicts a case where Microsoft Defender for Endpoint detects a malicious payload (which could come from any source, including personal email or a USB drive).



The victim receives a malicious email on a personal email account not protected by Microsoft Defender for Office 365 (MDO) or a USB drive and opens the attachment. Once the attachment opens, the malware infects the computer. The user is unaware that an attack occurred. But Microsoft Defender for Endpoint (MDE) detects this attack, raises an alert to security operations, and provides details about the threat to the Security team. Disable user access from device while infected - MDE communicates to Intune that the risk level on this endpoint has changed. An Intune Compliance Policy configured with an MDE risk level severity is triggered and marks the account as noncompliant with organizations policy. The Conditional Access created in Microsoft Entra ID blocks user access to apps.

Remediation

MDE remediates threat – either via automated remediation, security analyst approval of automated remediation, or analyst manual investigation of threat.
Microsoft Defender for Endpoint (MDE) also remediates this threat across your enterprise and across the broader MDE customer base by contributing information about this attack to the Microsoft Threat Intelligence system.

Share Intelligence and Restore Access

Restore Access – Once the infected devices are remediated, MDE signals Intune to change the device risk status and Microsoft Entra ID Conditional Access then allows access to enterprise resources (more on the next slide). Remediate Threat Variants in MDO and others – The threat signals in Microsoft Threat intelligence are used by Microsoft tools securing other parts of your organization's attack surface. MDO and Microsoft Defender for Cloud use the signals to detect and remediate threats in email, office collaboration, Azure, and more.

From the previous graphic when the user's device was still compromised



Access Restricted

Conditional Access knows about device risk because Microsoft Defender for Endpoint (MDE) notified Intune, which then updated the compliance status of the device in Microsoft Entra ID.

During this time, the user is restricted from accessing corporate resources. This applies to all new resource requests and blocks any current access to resources that support continuous access evaluation (CAE). People are able to do general internet productivity tasks, like research YouTube, Wikipedia, and anything else that doesn't require corporate authentication, but won't have access to corporate resources.

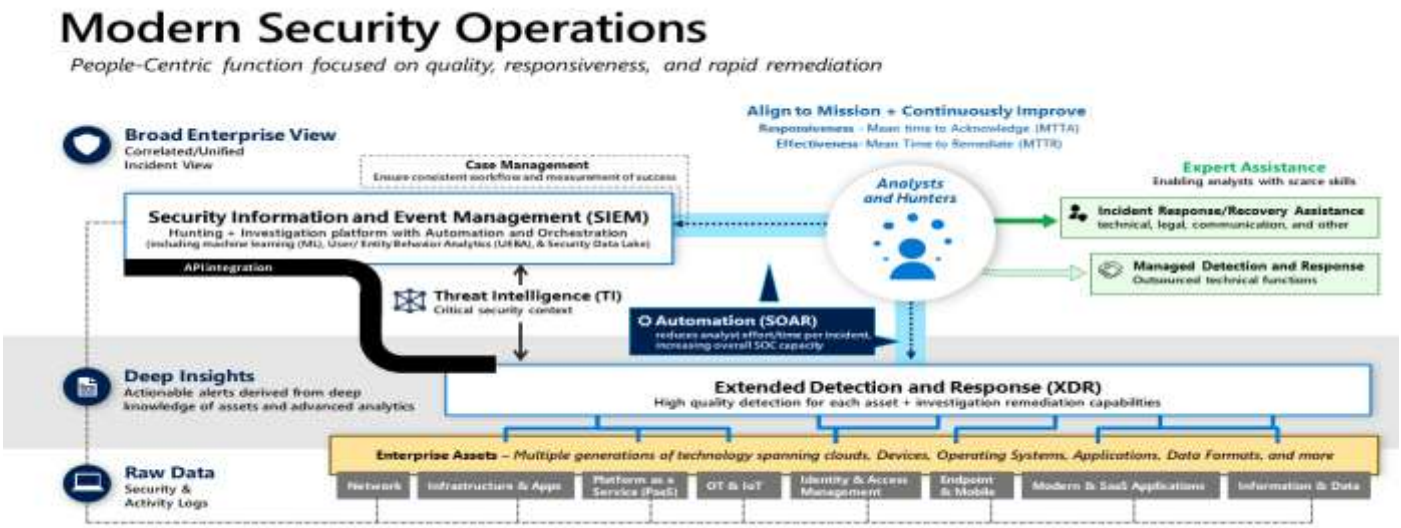
Access Restored

Once the threat has been remediated and cleaned up, MDE triggers Intune to update Microsoft Entra ID, and Conditional Access restores the user's access to corporate resources.

This mitigates risk to the organization by ensuring attackers who might be in control of these devices can't access corporate resources, while minimizing the impact on user productivity to minimize disruption of business processes.

Understand Microsoft Defender XDR in a Security Operations Center (SOC)

The following graphic provides an overview of how Microsoft Defender XDR and Microsoft Sentinel are integrated in a Modern Security Operations Center (SOC).

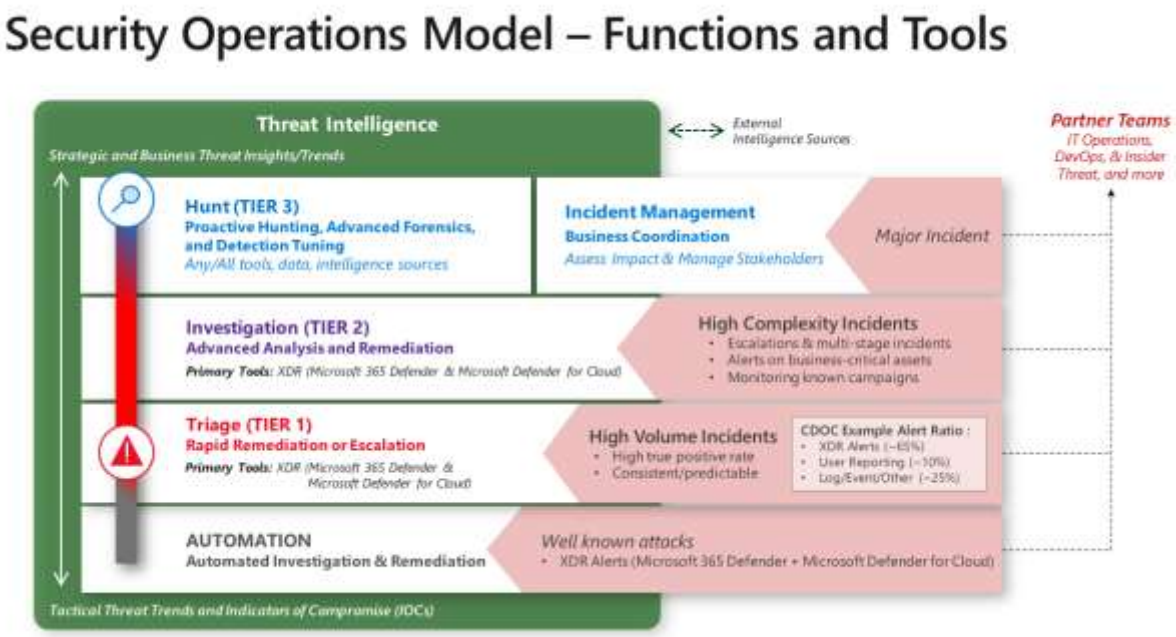


Security Operations Model - Functions and Tools

While the assignment of responsibilities to individual people and teams vary based on organization size and other factors, security operations are composed of several distinct functions. Each function/team has a primary focus area and also must collaborate closely with other functions and outside teams to be effective. This diagram depicts the full model with fully staffed teams. In smaller organizations, these functions are often combined into a single role or team, performed by IT Operations (for technical roles), or are performed as a temporary function by leadership/delegates (for incident management)

Note

We primarily refer to the analysts by the team name, not the Tier numbers as these teams each have unique specialized skills, they aren't a literal ranking/hierarchical of value.



Triage and Automation

We start with handling reactive alerts – which begins with:

Automation – Near real-time resolution of known incident types with automation. These are well-defined attacks that the organization has seen many times.

Triage (aka Tier 1) –Triage analysts focus on rapid remediation of a high volume of well-known incident types that still require (quick) human judgment. These are often tasked with approving automated remediation workflows and identifying anything anomalous or interesting that warrant escalation or consultation with investigation (Tier 2) teams.

Key learnings for Triage and Automation:

90% true positive - We recommend setting a quality standard of 90% true positive for any alert feeds that require an analyst to respond so analysts aren’t required to respond to a high volume of false alarms.

Alert Ratio – In Microsoft’s experience from our Cyber Defense Operations Center, XDR alerts produce most of the high-quality alerts, with the remainders coming from user reported issues, classic log query based alerts, and other sources

Automation is a key enabler for triage teams as it helps empower these analysts and reduce the burden of manual effort (for example, provide automated investigation and then prompt them for a human review before approving the remediation sequence that was automatically built for this incident).

Tool Integration - One of the most powerful time saving technologies that improved time to remediation in Microsoft's CDOC is the integration of XDR tools together into Microsoft Defender XDR so analysts have a single console for endpoint, email, identity, and more. This integration enables analysts to rapidly discover and clean up attacker phishing emails, malware, and compromised accounts before they can do significant damage.

Focus - These teams can't maintain their high speed of resolution for all types of technologies and scenarios, so they keep their focus narrow on a few technical areas and/or scenarios. Most often this is on user productivity, like email, endpoint AV alerts (versus EDR that goes into investigations), and first response for user reports.

Investigation and Incident Management (Tier 2)

This team serves as the escalation point for issues from Triage (Tier 1), and directly monitors alerts that indicate a more sophisticated attacker. Specifically alerts that trigger behavioral alerts, special case alerts related to business-critical assets, and monitoring for ongoing attack campaigns. Proactively, this team also periodically reviews the Triage team alert queue and can proactively hunt using XDR tools in their spare time.

This team provides deeper investigation into a lower volume of more complex attacks, often multi-stage attacks conducted by human attack operators. This team pilots new/unfamiliar alert types to document processes for Triage team and automation, often including alerts generated by Microsoft Defender for Cloud on cloud hosted apps, VMs, containers, and Kubernetes, SQL databases, etc.

Incident Management – This team takes on the nontechnical aspects of managing incidents including coordination with other teams like communications, legal, leadership, and other business stakeholders.

Hunt and Incident Management (Tier 3)

This is a multi-disciplinary team focused on identifying attackers that could have slipped through the reactive detections and handling major business-impacting events.

Hunt – This team proactively hunts for undetected threats, assists with escalations and advanced forensics for reactive investigations, and refines alerts/automation. These teams operate in more of a hypothesis-driven model than a reactive alert model and are also where red/purple teams connect with security operations.

How It Comes Together

To give you an idea of how this works, let's follow a common incident lifecycle

Triage (Tier 1) analyst claims a malware alert from the queue and investigates (for example, with Microsoft Defender XDR console)

While most Triage cases are rapidly remediated and closed, this time the analyst observes that malware might require more involved/advanced remediation (for example, device isolation and cleanup). Triage escalates the case to the Investigation analyst (Tier 2), who takes lead for investigation. The Triage team has option to stay involved and learn more (Investigation team might use Microsoft Sentinel or another SIEM for broader context)

Investigation verifies investigation conclusions (or digs further into it) and proceeds with remediation, closes case.

Later, Hunt (Tier 3) might notice this case while reviewing closed incidents to scan for commonalities or anomalies worth digging into:

Detections that might be eligible for autoremediation

Multiple similar incidents that might have a common root cause

Other potential process/tool/alert improvements In one case, Tier 3 reviewed the case and found that the user had fallen for a tech scam. This detection was then flagged as a potentially higher priority alert because the scammers had managed to get admin level access on the endpoint. A higher risk exposure.

Threat intelligence

Threat Intelligence teams provide context and insights to support all other functions (using a threat intelligence platform (TIP) in larger organizations). This could include many different facets including

Reactive technical research for active incidents

Proactive technical research into attacker groups, attack trends, high profile attacks, emerging techniques, etc.

Strategic analysis, research, and insights to inform business and technical processes and priorities.

And more

Explore Microsoft Security Graph

Microsoft Graph provides a unified programmability model that you can use to access the data in Microsoft 365, Windows, and Enterprise Mobility + Security. You can use the data in Microsoft Graph to build customized apps for your organization.

The Microsoft Graph API offers a single endpoint, https://graph.microsoft.com (either v1.0 or beta versions). You can use REST APIs or SDKs to access the endpoint and build apps that support Microsoft 365 scenarios. Microsoft Graph also includes a powerful set of services that manage user and device identity, access, compliance, and security and help protect organizations from data leakage or loss.

What's in Microsoft Graph?

Microsoft Graph exposes REST APIs and client libraries to access data on the following Microsoft cloud services:

Microsoft 365 core services: Bookings, Calendar, Excel, Microsoft Lists, Microsoft Purview eDiscovery, Microsoft Search, OneDrive, OneNote, Outlook/Exchange, People (Outlook contacts), Planner, SharePoint, Teams, To Do, Viva Insights

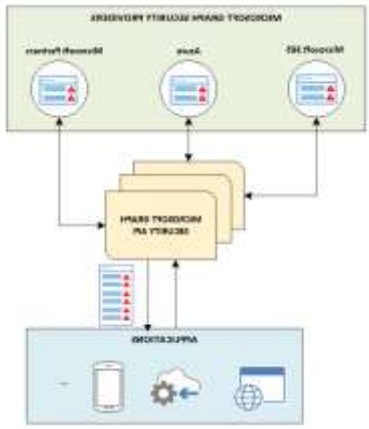
Enterprise Mobility + Security services: Microsoft Defender for Identity, Microsoft Entra ID, and Intune

Windows services: activities, devices, notifications, Universal Print

Dynamics 365 Business Central services

Microsoft Graph Security API

The Microsoft Graph security API is an intermediary service (or broker) that provides a single programmatic interface to connect multiple Microsoft Graph security providers (also called security providers or providers). Requests to the Microsoft Graph security API are federated to all applicable security providers. The results are aggregated and returned to the requesting application in a common schema, as shown in the following diagram.



Developers can use the Security Graph to build intelligent security services that:

Integrate and correlate security alerts from multiple sources.

Stream alerts to security information and event management (SIEM) solutions.

Automatically send threat indicators to Microsoft security solutions to enable alert, block, or allow actions.

Unlock contextual data to inform investigations.

Discover opportunities to learn from the data and train your security solutions.

Automate SecOps for greater efficiency.

Use the Microsoft Graph Security API

There are two versions of the Microsoft Graph Security API.

Microsoft Graph REST API v1.0

Microsoft Graph REST API Beta

The beta version provides new or enhanced APIs that are still in preview status. APIs in preview status are subject to change, and may break existing scenarios without notice.

For Security Operations Analysts, both Microsoft Graph API versions support advanced hunting using the runHuntingQuery method. This method includes a query in Kusto Query Language (KQL).

Advanced hunting example in Microsoft Defender XDR:

HTML

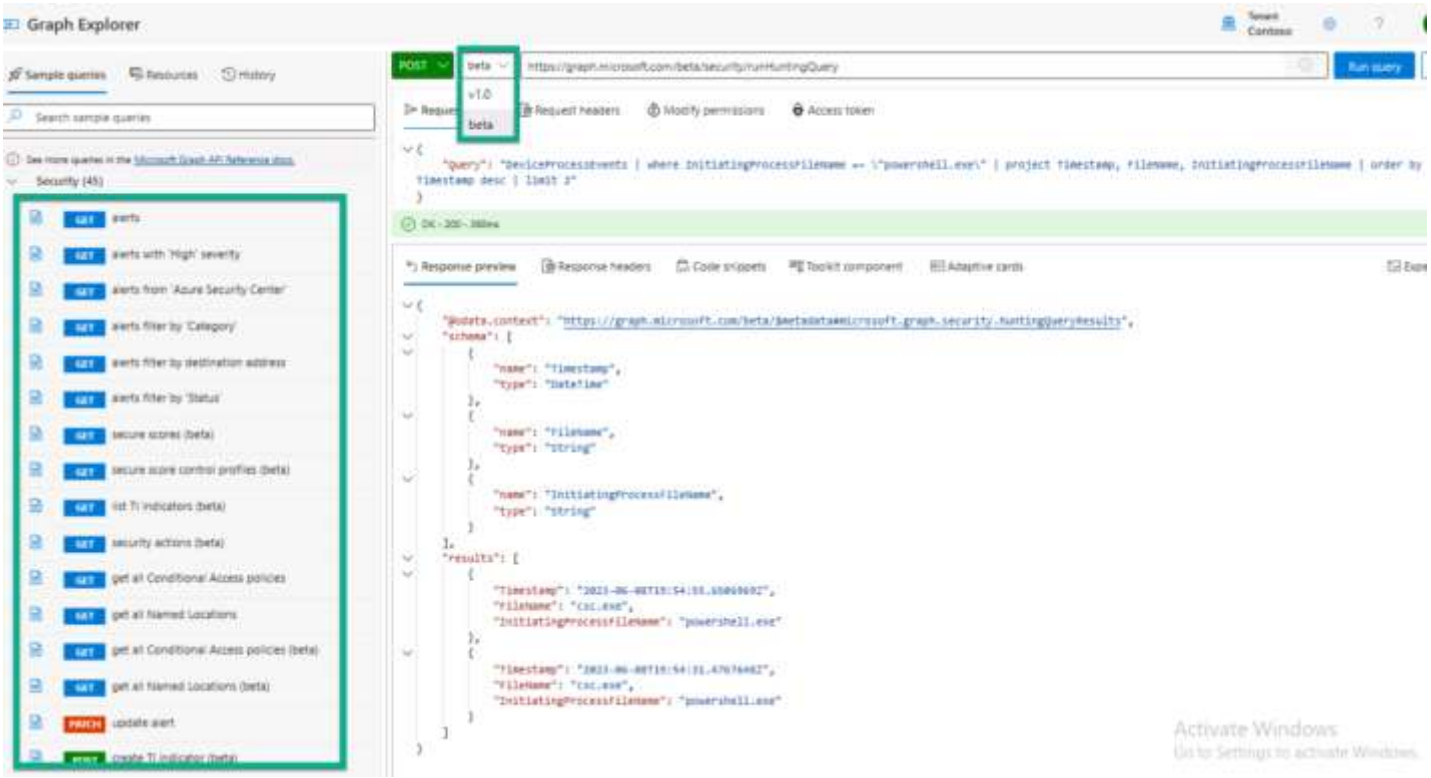
POST https://graph.microsoft.com/v1.0/security/runHuntingQuery

{

"Query": "DeviceProcessEvents | where InitiatingProcessFileName =~ \"powershell.exe\" | project Timestamp, FileName, InitiatingProcessFileName | order by Timestamp desc | limit 2"

}

You can use Graph Explorer to run the hunting query:



Additional reading - For more information, see The Microsoft Graph Security API.

Investigate security incidents in Microsoft Defender XDR

The following cloud guide demonstrates Microsoft Defender XDR and Microsoft Sentinel working together to investigate a security incident in a hybrid environment.

Investigate security incidents in a hybrid environment